

Nová směrnice EU o kybernetické bezpečnosti NIS2 Nový zákon o kybernetické bezpečnosti

Prof. Ing. Cyril Klimeš, CSc.

Základní informace

- Evropská unie již v roce 2016 přijala směrnici NIS (6.6.2016)
- Její účel je zajištění vysoké společné úrovně bezpečnosti sítí a informačních systémů v Unii
- Oficiální znění v Úředním věstníku NIS2 (16.1.2023)
- Nový český Zákon o KB byl následně schválen (2024) schválen a účinný od r. 2025.

Nejvýznamnější povinnosti

- stát určí jeden ze svých týmů CSIRT (CERT) jakožto koordinátora za účelem koordinovaného zveřejňování zranitelností
- Vzájemná pomoc mezi dozorovými orgány (systémy vzájemné kontroly a regulace)
- Větší zapojení Evropské komise do sjednocení regulace v členských státech
- Významné zvýšení pokut za nedodržení uložených povinností
 - „essential entity“ - horní hranice sazby bude stanovena na nejméně 10 milionů EUR nebo na alespoň 2 % celkového celosvětového ročního obrátu

Stěžejní změny v regulaci

- Návrhu zcela nové regulace kybernetické bezpečnosti (NÚKIB)
- Návrh zákona o kybernetické bezpečnosti sdružuje dosavadní roztržitou úpravu několika typů povinných osob do jedné – tzv. poskytovatele regulované služby
 - musí naplňovat kritéria stanovená navrhovanou vyhláškou o regulovaných službách

Povinnosti poskytovatele regulované služby jsou :

- Nastavení **systemu řízení rizik** v rámci vlastních sítí a informačních systémů.
- Zavedení **minimálního standardu** kyberbezpečnostních opatření včetně bezpečnosti dodavatelského řetězce, řízení zranitelností a hodnocení řízení rizik kybernetické bezpečnosti.
- **Vytvoření týmu**, který bude schvalovat opatření v oblasti kyberbezpečnosti a dohlížet na jejich dodržování.
- **Klasifikace používaných aplikací** a systémů včetně vytvoření plánu jejich obnovy a provádění penetračních testů.
- **Používání silných hesel, dvoufaktorového ověřování** nebo certifikátů pro přihlašování uživatelů do kriticky důležitých systémů.
- **Aplikování bezpečnostních aktualizací** vydaných výrobcí softwaru.
- **Lokalizace dat** – primární ukládání dat na území České republiky s možností ukládat data v šifrované podobě v rámci dalších zemí EU, NATO nebo Organizace pro ekonomickou spolupráci.
- **Hlášení kyberbezpečnostních incidentů** NÚKIB a provádění pravidelných aktualizací a revizí procesů na zajištění kybernetické bezpečnosti včetně vytváření souvisejících zpráv.

Koho se nové povinnosti týkají

- Dosavadní regulace jen pro úzkou skupinu několika stovek nejvýznamnějších organizací, které mají dopad na celou společnost
- Nová směrnice se bude týkat všech poskytovatelů služeb důležitých pro fungování společnosti

Na která odvětví a typy subjektů se NIS 2 vztahuje

- Směrnice rozšiřuje oblast působnosti o **nová odvětví**
- Doposud se subjekty dělí na provozovatele základních služeb a poskytovatele digitálních služeb
- Subjekty jsou nově děleny na **základní** a **důležité**, a to v návaznosti na kritickou důležitost daného odvětví/služby a úroveň závislosti jiných odvětví/služeb na daném odvětví.
- Od základních společností se budou vyžadovat přísnější kybernetická opatření a budou podléhat ex-ante kontrole ze strany NÚKIBu, zatímco druhá skupina bude kontrolována ex-post.

Podmínky

- Aby soukromá nebo veřejná organizace spadala pod regulaci směrnice, musí splňovat tyto dvě podmínky:
 1. organizace poskytuje alespoň jednu službu uvedenou v přílohách směrnice a zároveň
 2. je středním nebo velkým podnikem, tedy zaměstnává 50 a více zaměstnanců, nebo dosahuje ročního obrátu či bilanční sumy roční rozvahy alespoň 10 milionů EUR (zhruba 250 milionů CZK) - *pozor u tzv. partnerských nebo propojených podniků*

Organizace, poskytující určité služby, spadají pod regulaci bez ohledu na velikost (elektronické komunikace, poskytovatelé služeb vytvářejících důvěru, poskytovatelé služeb DNS

SLUŽBY UVEDENÉ V PŘÍLOZE I

Subjekty poskytující služby uvedené v příloze I níže a splňující podmínku „velký podnik“ dle doporučení Komise (EU) 2003/361/EC budou regulovány vždy v režimu „essential“.

ENERGETIKA

 Provozovatelé distribuční a přenosové soustavy, výrobci a prodejci elektrické energie, nominovaní organizátoři trhu s elektřinou, provozovatelé dobíjecích stanic spolu s poskytovateli elektromobility.

 Subjekty poskytující službu dálkového vytápění nebo chlazení.

 Provozovatelé ropovodů, zařízení na těžbu, rafinaci a zpracování ropy, skladovacích a přenosových zařízení, ústřední správci zásob.

 Obchodníci s plynem, distributoři plynu, přepravci plynu, výrobci plynu a poskytovatelé uskladňování plynu.

 Provozovatelé výroby, skladování a přepravy vodíku. Doposud však není implementováno do českého právního řádu.

DOPRAVA

 Komerční leteckí dopravci, řídicí orgány letišť a subjekty provozující pomocná zařízení v rámci letišť, provozovatelé kontroly řízení provozu.

 Provozovatel dráhy celostátní nebo regionální anebo veřejné přístupné vlečky a dopravce provozující na těchto drahách drážní dopravu.

 Předmětné předpisy se vztahují na námořní přístavy a pro Českou republiku tedy nejsou relevantní.

 Silniční orgány odpovědné za plánování, kontrolu a správu silnic spadajících do jejich územní působnosti, poskytovatelé služeb ITS.

BANKOVNICTVÍ

 Sektor bankovníctví je regulován nařízením DORA.

INFRASTRUKTURA FIN. TRHŮ

 Sektor infrastruktura finančních trhů je regulován nařízením DORA.

ZDRAVOTNICTVÍ

 Poskytovatelé zdravotní péče (nemocnice a další), subjekty provádějící výzkum a vývoj léčivých výrobků a přípravků, výrobci základních farmaceutických přípravků.

PITNÁ VODA

 Dodavatelé a distributoři vody určené k lidské spotřebě, avšak kromě těch, pro které je to vedlejší činnost k jejich hlavní činnosti zabývající se distribucí jiných komodit a zboží.

ODPADNÍ VODA

 Subjekty shromažďující, vypouštějící nebo upravující městské nebo průmyslové odpadní vody nebo splašky, avšak kromě těch, pro které se jedná pouze o vedlejší činnost k jejich hlavní činnosti.

DIGITÁLNÍ INFRASTRUKTURA

 Poskytovatelé: výměnných uzlů internetu (IXP), cloud computingu, datového centra, služeb vytvářejících důvěru, elektronických komunikací, CDN služeb, registrů TLD, služeb systému doménových jmen (DNS), s výjimkou poskytovatelů root name serverů.

POSKYTOVATELÉ ŘÍZENÝCH ICT SLUŽEB

 Poskytovatelé řízených ICT služeb a poskytovatelé řízených ICT bezpečnostních služeb. Subjekty, pro zákazníky provozující či spravující ICT služby a nástroje, typicky na základě smlouvy o úrovni služeb (SLA).

VEŘEJNÁ SPRÁVA

 Ústřední orgány státní správy, veřejná správa na regionální úrovni, soudy a státní zastupitelství a další instituce významné pro chod státu.

VESMÍR

 V České republice nejsou umístěny žádné subjekty pozemní infrastruktury, pro Českou republiku tedy nerelevantní.

SLUŽBY UVEDENÉ V PŘÍLOZE II

Subjekty poskytující služby uvedené v příloze I a splňující podmínku „střední podnik“ a subjekty poskytující služby uvedené v příloze II a splňující podmínku „velký podnik“ a „střední podnik“ dle doporučení Komise (EU) 2003/361/EC budou regulovány v režimu „important“ (nižší nároky z hlediska bezpečnostních opatření), pokud nebude stanoveno speciálními kritérii jinak.

POŠTOVNÍ SLUŽBY

 Subjekty, poskytující poštovní služby, tzn. výběr, třídění, přepravu a dodání poštovních zásilek, včetně provozovatelů kurýrních služeb.

ODPADNÍ HOSPODÁŘSTVÍ

 Subjekty, poskytující službu nakládání s odpady, tzn. zařízení určená pro nakládání s odpady, obchodníci, zprostředkovatelé, dopravci podle zákona č. 541/2020 Sb., kromě těch, pro které nakládání s odpady není jejich hlavní ekonomickou činností.

CHEMICKÝ PRŮMYSL

 Subjekty, poskytující služby v chemickém průmyslu, tzn. výrobci, distributoři, včetně maloobchodníka, který skladuje a uvádí na trh chemickou látku nebo předmět.

POTRAVINÁŘSTVÍ

 Potravinářské subjekty, které se zabývají velkoobchodní distribucí a průmyslovou výrobou nebo zpracováním.

VÝROBA

 Výroba: zdravotnických a diagnostických zdravotnických prostředků, počítačů, elektronických a optických přístrojů, elektrických zařízení, strojů a zařízení, motorových vozidel (kromě motocyklů), přívěsů a návěsů, ostatních dopravních prostředků a zařízení.

POSKYTOVATELÉ DIGI SLUŽEB

 Poskytovatelé on-line tržišť, internetových vyhledávačů, platform služeb sociálních sítí.

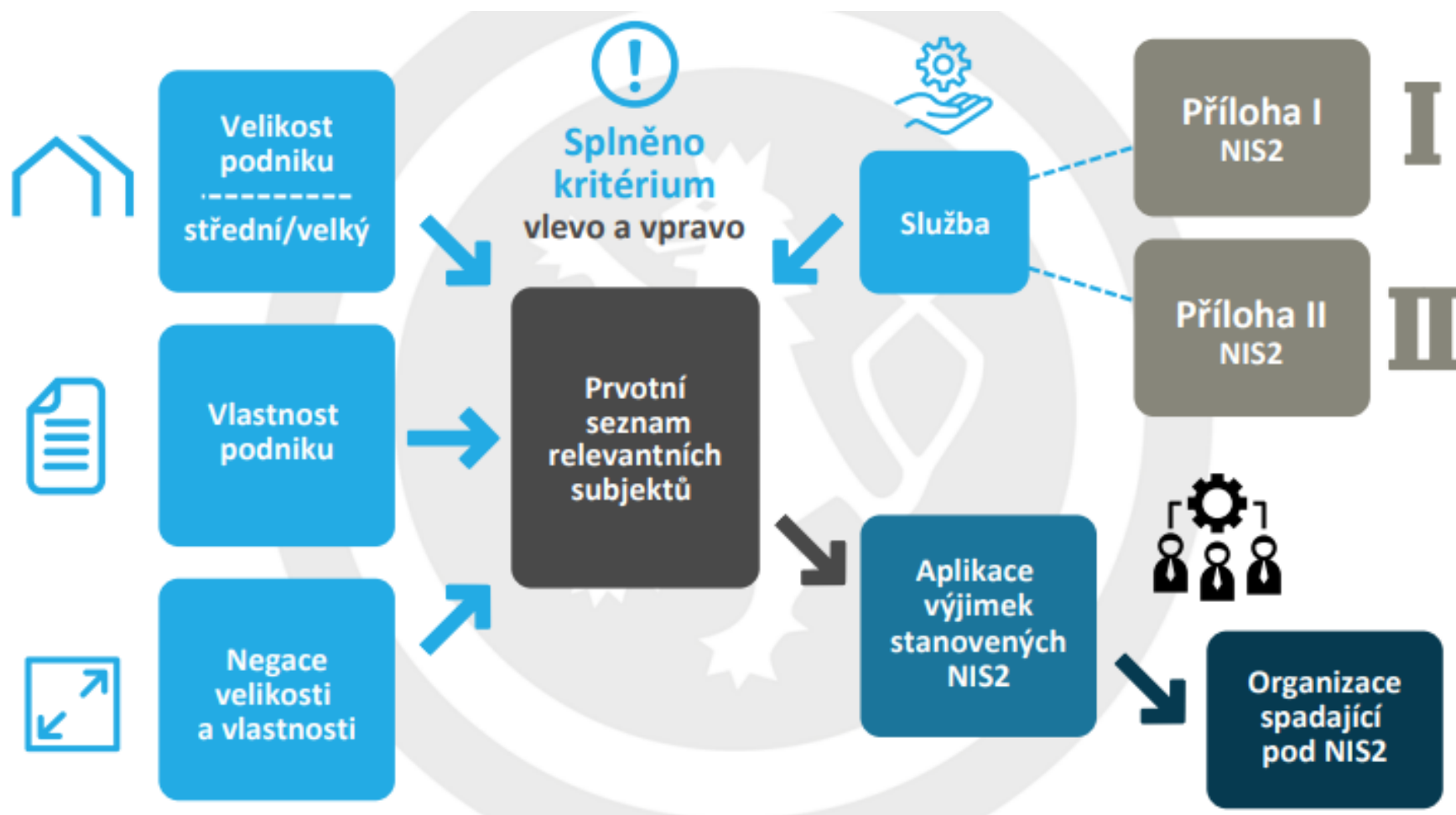
VÝZKUM

 Výzkumné organizace, s výjimkou vzdělávacích institucí, jejichž hlavním cílem je provádět aplikovaný výzkum nebo experimentální vývoj s ohledem na využití výsledků tohoto výzkumu pro komerční účely.

SUBJEKTY, KTERÝM PLYNOU POVINNOSTI Z NIS2, ALE NESPADAJÍ DO REŽIMU ESSENTIAL, ANI IMPORTANT

 Subjekty shromažďující a udržující přesnou a úplnou registraci názvu domén.

Určení organizace



Prahové hodnoty

Kategorie podniku	Počet zaměstnanců: roční pracovní jednotka (RPJ)	Roční obrát	nebo	Bilanční suma roční rozvahy
Střední podnik	< 250	≤ 50 milionů EUR	nebo	≤ 43 milionů EUR
Malý podnik	< 50	≤ 10 milionů EUR	nebo	≤ 10 milionů EUR
Mikropodnik	< 10	≤ 2 miliony EUR	nebo	≤ 2 miliony EUR

Základní dělení – základní, důležité

Příloha NIS2

I

II

Velikost organizace

Velká

ESSENTIAL

IMPORTANT

Střední

IMPORTANT

IMPORTANT

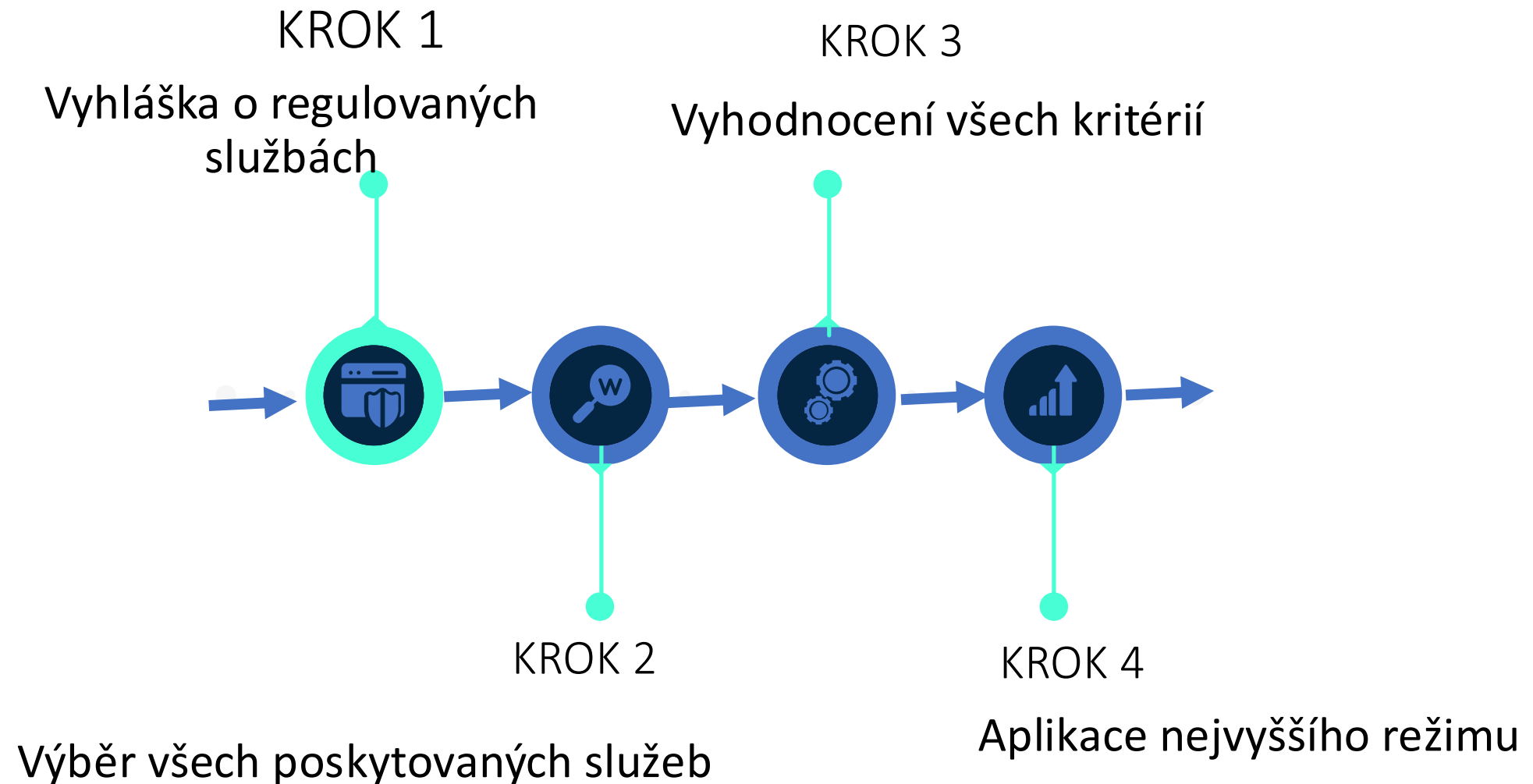
Základní entity:

- zdravotnictví,
- výroba farmaceutických výrobků,
- energetika,
- doprava,
- bankovníctví,
- infrastruktury finančních trhů,
- digitální infrastruktura,
- pitná voda,
- odpadní vody,
- veřejná správa,
- vesmír.

Důležité entity:

- poštovní a kurýrní služby,
- nakládání s odpady,
- výroba (zdravotnických prostředků, počítačů, elektronických a optických zařízení, elektrozařízení, strojů, motorových vozidel, přívěsů a návěsů, ostatních dopravních prostředků a zařízení),
- výroba, zpracování a distribuce potravin,
- výroba a distribuce chemikálií,
- digitální poskytovatelé.

STANOVENÍ REŽIMU POSKYTOVATELE REGULOVANÉ SLUŽBY



Tisíce nově regulovaných subjektů!!!!!!!!!!!!!!

- V případě vybraných základních a důležitých subjektů budou zahrnuty veškeré tyto subjekty bez ohledu na jejich velikost. (například poskytovatelé služeb elektronických komunikací nebo poskytovatelé důvěryhodných služeb).

OPATŘENÍ K ŘÍZENÍ RIZIK

- Opatření k řízení rizik v oblasti kybernetické bezpečnosti mají zahrnovat alespoň následující aspekty:
 - analýzu rizik a politiku bezpečnosti informačních systémů
 - řešení incidentů (prevence a odhalování incidentů a reakce na ně),
 - řízení kontinuity provozu a krizové řízení,
 - zabezpečení dodavatelského řetězce
 - zabezpečení pořizování, vývoje a údržby sítě a informačních systémů,
 - politiky a postupy (testování a audit v oblasti kybernetické bezpečnosti),
 - používání kryptografie a šifrování.

OPATŘENÍ K ŘÍZENÍ incidentů

- **Povinnost neprodleně oznamovat každý incident**, který má závažný dopad na poskytování služeb dotčeného subjektu, i každou významnou kybernetickou hrozbu, kterou tyto subjekty zjistí, a která by mohla mít za následek významný incident,

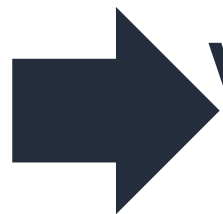
Přímá odpovědnost

- Nově bude zavedena **přímá odpovědnost statutárních orgánů** za zavedení kyberbezpečnostních opatření a jejich následné dodržování.
- Nebude tak dostačující problematiku kybernetické bezpečnosti delegovat na firemní IT oddělení, ale vedení firmy se bude muset o kybernetickou bezpečnost ve vlastním zájmu samo zajímat, jinak mohou za případný kybernetický incident nést přímou odpovědnost.

Přizpůsobení kategorií

**"Základní subjekty"
mají přísnější
povinnosti**

**"Důležité subjekty"
mají
méně přísné povinnosti**



**Vytvoření dvou sad pravidel pro
kybernetickou bezpečnost**

Nižší povinnosti

- Zajišťování minimální úrovně kybernetické bezpečnosti
- Povinnosti vrcholného vedení
- Řízení rizik
- Bezpečnost lidských zdrojů
- Řízení kontinuity činností
- Řízení přístupu
- Řízení identit a jejich oprávnění
- Detekce a zaznamenávání kybernetických bezpečnostních událostí
- Řešení kybernetických bezpečnostních incidentů
- Bezpečnost komunikačních sítí
- Aplikační bezpečnost
- Kryptografické algoritmy

Vyšší povinnosti

Organizační opatření

- Systém řízení bezpečnosti informací
- Povinnosti vrcholného vedení
- Bezpečnostní role
- Řízení bezpečnostní politiky a bezpečnostní dokumentace
- Řízení aktiv
- Řízení rizik
- Řízení dodavatelů
- Bezpečnost lidských zdrojů
- Řízení změn
- Akvizice, vývoj a údržba
- Řízení přístupu
- Zvládání kybernetických bezpečnostních událostí a kybernetických bezpečnostních incidentů
- Řízení kontinuity činnosti
- Audit kybernetické bezpečnosti

Technické opatření

- Fyzická bezpečnost
- Bezpečnost komunikačních sítí
- Správa a ověřování identit
- Řízení přístupových oprávnění
- Detekce kybernetických bezpečnostních událostí
- Zaznamenávání bezpečnostních a relevantních provozních událostí
- Vyhodnocování kybernetických bezpečnostních událostí
- Aplikační bezpečnost
- Kryptografické algoritmy
- Zajišťování dostupnosti regulované služby a
- Zabezpečení průmyslových, řídicích a obdobných specifických technických aktiv

Regulované služby s vyšším režimem

- veřejná správa
- energetika (elektřina, dálkové vytápění a chlazení, ropa, plyn a vodík)
- doprava (letecká, železniční, vodní a silniční)
- bankovníctví a infrastruktury finančních trhů
- zdravotnictví a výroba farmaceutických a zdravotnických prostředků
- pitná voda a odpadní vody
- digitální infrastruktura, výměnné uzly internetu, poskytovatelé služeb DNS, registry internetových domén nejvyšší úrovně (TLD)
- poskytovatelé služeb cloud computingu, poskytovatelé služeb datových center a sítě pro doručování obsahu
- poskytovatelé služeb vytvářejících důvěru a veřejné sítě elektronických komunikací a služby elektronických komunikací
- vesmír

Organizace s nižším režimem

- výroba strojního zařízení
- výroba počítačů a elektroniky
- výroba motorových vozidel
- výroba jiných zdravotnických prostředků
- výroba potravin
- digitální poskytovatelé (internetová tržiště, internetové vyhledávače a platformy služeb sociálních sítí)
- poštovní a kurýrní služby
- nakládání s odpady, chemické látky

Test zařazení organizace

- <https://www.datasys.cz/nis2/>
- *Mikropodnik – zaměstnávají méně než 10 osob a jejichž roční obrat a/nebo bilanční suma roční rozvahy nepřesahuje 2 miliony EUR.*
- *Malý podnik – zaměstnávají méně než 50 osob a jejichž roční obrat a/nebo bilanční suma roční rozvahy nepřesahuje 10 milionů EUR.*
- *Střední podnik – zaměstnávají více než 50 a méně než 250 osob, jejichž roční obrat nepřesahuje 50 milionů EUR a/nebo jejichž bilanční suma roční rozvahy nepřesahuje 43 milionů EUR*
- *Pokud nevíte do jakého oddílu klasifikace CZ-NACE patříte, můžete využít [Registr ekonomických subjektů](#), kde oddíl určuje první dvojčíslí. Formulář je sestaven na základě návrhu zákona o kybernetické bezpečnosti ze dne 19.6.2023*

Zavést směrnice informační bezpečnosti znamená

- mít základní směrnice kolem bezpečnosti, jako je například Bezpečnostní politika, politika hesel, přidělování oprávnění a další
- mít dokumentaci k prokázání shody s NIS2

Řízení bezpečnosti znamená

- mít pod kontrolou komu a proč dávám oprávnění k nějaké aplikaci
- mít pod kontrolou, kdo zná jaká hesla
- mít pod kontrolou, kdo má, kam přístup ve firmě (klíče, vstupní karty)
- mít pod kontrolou, kdo kam ukládá jaké informace
- mít pod kontrolou, že když odchází zaměstnanec, tak mu odeberete všechny přístupy
- když nastupuje zaměstnanec, že mu dáváte přístupy, kam